VibeScan: Multi-Dimensional Benchmark Analysis for JavaScript Security Scanning

Bridging vulnerability detection and validation in web security through proof-based analysis and comprehensive evaluation across recall, runtime, and signal efficiency

AUTHORS: JOSH OBERSTEADT, ANDREW YOUSSEF

Mentors: Kevin Brunner | Aquilla Galusha

Abstract

Security vulnerabilities in web applications remain a persistent challenge. Veracode's industry study of applications *developed in EMEA* reported that roughly 80% contained at least one security flaw,[2] underscoring scale; most static analysis tools still cannot determine whether a vulnerability is genuinely reachable or exploitable. The result is that developers are left managing high volumes of alerts with little confidence about where real risk exists.

We introduce VibeScan, a static analysis framework evaluated on the DVNA benchmark against five widely used peer scanners.[1,5] VibeScan achieved 100% recall across all confirmed vulnerability cases while completing full analysis in under one second, demonstrating that comprehensive detection is achievable within practical CI/CD constraints.

Beyond recall, we introduce a cases per alert metric to evaluate signal efficiency across tools. Our findings show that high detection coverage and low alert noise are not mutually exclusive. This work contributes a proof oriented analysis approach, a multi-dimensional benchmarking methodology, and a reproducible evaluation framework for the JavaScript security tooling community.

Research Gap & Contributions

WHY EXISTING TOOLS FALL SHORT

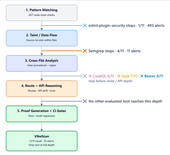
- Static analysis tools do not determine whether vulnerabilities are actually reachable or exploitable
- Developers are left manually triaging large volumes of low confidence alerts
- Most scanners stop at syntax or single file data flow
- No cross file context and no route level reasoning
- OWASP Top 10 families remain incompletely covered across peer tools

WHAT VIBESCAN CONTRIBUTES

- Unified pipeline combining rule detection, taint flow, and route reasoning
- Auto generated proof test linked to every finding
- Executable evidence, not just a line number
- CI recall gates that prevent coverage regression before each merge
- Addresses the full OWASP Top 10: 2025 risk set

VibeScan Framework

FIGURE 1 — ANALYSIS DEPTH COMPARISON



This diagram shows where each peer tool stops in the analysis pipeline and why VibeScan reaches vulnerabilities that others miss.

EVALUATION & COMPARISON

Tools: 1 VibeScan 2 Bearer 3 Snyk Code 4 Semgrep 5 CodeQL 6 ESLint

FIGURE 2 — COVERAGE BY VULNERABILITY CATEGORY (DVNA CORE)

VibeScan is the only tool with full coverage across all vulnerability categories, especially outperforming in complex injection and client-side cases.

Category · Scenarios covered		1 VibeScan	2 Bearer	3 Snyk	4 Semgrep	5 CodeQL	6 ESLint
Injection	SQL, Command, NoSQL (3 contexts) (5)	100%	100%	40%	20%	40%	20%
Redirect & Nav	Open Redirect (1)	100%	100%	100%	100%	100%	0%
Integrity	Unsafe Deserialization (1)	100%	0%	100%	100%	100%	0%
Secrets & Crypto	Secrets + Weak Hash (2)	100%	100%	50%	50%	50%	0%
Auth & Client	Env + XSS (2)	100%	0%	50%	0%	50%	0%
Overall recall (11 cases)		100%	72.7%	63.6%	36.4%	54.5%	9.1%

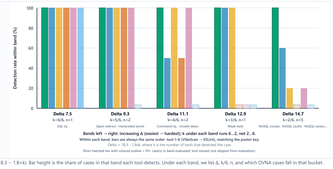
VibeScan achieves 100% coverage across all five OWASP aligned vulnerability families. Peer tools perform well on injection and redirect cases but drop sharply in authentication and client side categories, where cross file and route level reasoning is required.

FIGURE 3 — RECALL VS. RAW ALERT VOLUME

Recall vs. raw alert volume on DVNA. X-axis shows issue count on a logarithmic scale (tick labels are actual counts), so both low-volume and high-volume tools are readable on one chart. Point colors match the tool key. Pearson r shown for linear counts.

Tools that generate more alerts do not find more vulnerabilities. ESLint fires over 500 alerts and catches one case out of eleven. VibeScan fires 25 alerts and catches all 11. The negative correlation confirms that alert volume alone is not a reliable measure of scanner quality (see [1]).

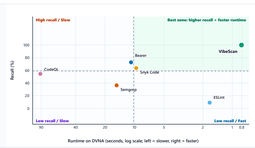
FIGURE 4 — COVERAGE BY DIFFICULTY BAND (DVNA CASES)



DVNA adjudicated test cases grouped into difficulty bands using six-tool consensus k (mapped to research Δ = 18.3 − 1.8×k). Bar height is the share of cases in that band each tool detects. Under each band, we list Δ, k/6, n, and which DVNA cases fall in that bucket.

VibeScan maintains full coverage across all difficulty levels, including the most complex DVNA cases in the rightmost bands, which require deeper contextual reasoning across data flow, application behavior, and cross file interactions. In contrast, peer tools perform well on simpler scenarios but show a clear drop in coverage as difficulty increases, highlighting a gap where detection performance declines as analysis becomes more complex.

FIGURE 5 — SCANNER EFFICIENCY (RECALL VS. RUNTIME)



Higher and farther right indicates a better balance of recall and runtime.

VibeScan is the only tool that lands in the high recall and fast runtime region of the chart, finishing full analysis in under one second. CodeQL is both the slowest tool and the lowest performer on recall.

Evaluation & Comparison

Metric	VibeScan	Bearer	Snyk	CodeQL	Semgrep	ESLint
Detection (DVNA)	**11/11**	8/11	7/11	6/11	4/11	1/11
Proof Support	Yes	No	No	No	No	No
Actionability	High	Medium	Medium	Medium	Low–Med	Low

VibeScan is the only tool evaluated that provides proof support for every finding. No peer tool matches its combination of detection coverage, signal efficiency, and actionability.

Citations

Industry evidence

1. [1] AppSecCo. *Damn Vulnerable Node Application (DVNA): GitHub repository.* https://github.com/appsecco/dvna.
2. [2] Veracode (industry research). *Veracode research reveals 80% of applications developed in EMEA contain security flaws.* Business Wire (Sept. 2023). https://www.businesswire.com/news/home/20230925296799/en/Veracode-Research-Reveals-80-of-Applications-Developed-in-EMEA-Contain-Security-Flaws. (EMEA-specific sample; not a global estimate.)
3. [3] Akamai. *Web attacks up 33%; APIs emerge as primary targets.* Newsroom press release, 22 Apr. 2025. https://www.akamai.com/newsroom/press-release/akamai-research-web-attacks-up-33-apis-emerge-as-primary-targets.
4. [4] Verizon. *2025 Data Breach Investigations Report (DBIR) highlights.* News release, 23 Apr. 2025. https://www.verizon.com/about/news/2025-data-breach-investigations-report.

Tools evaluated (documentation)

5. [5] Peer scanners benchmarked in this study: Semgrep semgrep.dev/docs; CodeQL codeql.github.com/docs; Snyk Code (CLI) docs.snyk.io/developer-tools/snyk-cli/commands/code-test; Bearer docs.bearer.com; eslint-plugin-security github.com/eslint-community/eslint-plugin-security.

Peer-reviewed research

6. [6] Johnson, B., Song, Y., Murphy-Hill, E., and Bowdidge, R. *Why Don't Software Developers Use Static Analysis Tools to Find Bugs?* ICSE 2013. DOI: 10.1109/ICSE.2013.6606613.